Section 1 — Incident Header

Incident ID: INC-20260416-004
Date: 16 April 2026
Time Opened (IST): 23:47
Severity: High
Client: LegalEdge Law Firm
Industry: Legal
L1 Analyst: Priya Nair
L2 Analyst: Rohan Desai
L3 Analyst: Nisha Kapoor
Current Status: Under Investigation
Sentinel Incident Number: 458921

Section 2 — Client & Environment Context

LegalEdge Law Firm is a mid-sized legal services organization headquartered in Mumbai, specializing in corporate litigation, intellectual property disputes, and high-value merger and acquisition advisory. The firm employs approximately 600 staff, including 220 practicing attorneys who routinely handle confidential client materials — ranging from pre-merger financial disclosures to sealed court filings and privileged communications. This makes LegalEdge an inherently high-value target for both external attackers and insider threats, particularly those seeking sensitive legal intelligence or monetizable confidential data.

The firm operates in a hybrid infrastructure model. On-premises Active Directory manages identity for internal systems, synchronized to Azure AD using Azure AD Connect. All users are provisioned with Microsoft 365 E5 licenses, enabling full deployment of Microsoft Defender for Endpoint, Defender for Office 365, Defender for Identity, and Microsoft Purview for data governance and DLP enforcement.

The endpoint estate consists of approximately 520 Windows 10/11 workstations and 45 Windows Server 2022 systems, including two domain controllers hosted on-premises. SharePoint Online is heavily used by legal teams to store case files, contracts, and evidence documentation. Access to sensitive document libraries is role-based, but attorneys often retain broad access across multiple case folders due to the collaborative nature of legal work.

From a compliance standpoint, LegalEdge adheres to ISO 27001 standards and is subject to client-imposed confidentiality clauses, particularly from multinational corporate clients. Data leakage — whether accidental or intentional — carries significant legal and reputational consequences.

Of particular relevance to this incident: the HR system had recently flagged a senior associate from the corporate litigation team as having submitted a formal resignation three days prior. This user still retained full access to multiple high-value SharePoint repositories tied to ongoing cases.

Section 3 — Attack Narrative (Attacker Perspective)

The decision had already been made days ago.

Three nights earlier, the resignation email had been sent — carefully worded, professionally timed. It bought just enough cover. Access would remain intact, at least for a short window. That window was all that mattered.

By 23:12 IST, the office network was quiet. No late-night Teams chatter. No document edits lighting up activity logs. The silence was predictable — and useful.

The first step was reconnaissance, not through tools, but through familiarity. Years of working inside the firm had already mapped out where the valuable data lived: the M&A SharePoint libraries, the litigation archives, the folders tagged with client names that never appeared in public filings.

A browser session opened to SharePoint Online. Authentication was seamless — no MFA challenge, not at this hour, not from a familiar device. The dashboard loaded exactly as it had every working day. Nothing had changed. That was the vulnerability.

Navigation was deliberate. No searching — direct paths. Folder after folder opened in sequence:
"/Corporate/ActiveDeals/Q4/Confidential"
"/Litigation/Ongoing/Client-Files/Restricted"

Bulk selection began quietly. Entire directories — hundreds of documents at a time. Contracts, due diligence reports, internal memos, email exports. The kind of data that held value far beyond the firm itself.

At 23:18, the first download initiated.

The system did not resist. No prompts. No warnings. Just a progress bar slowly filling as gigabytes of data streamed locally. The process repeated — select, download, repeat. Each batch carefully chosen to avoid drawing attention through erratic behavior. Consistent pacing. No spikes.

A local staging folder on the workstation filled rapidly. Files compressed into archives — not encrypted, not yet. That would come later. The goal here was extraction, not concealment.

By 23:36, over 2 gigabytes had been transferred.

There was a moment of pause — not hesitation, but calculation. Enough had been taken to matter. Enough to sell, or leverage, or hold.

The browser tabs were closed one by one. No traces cleared. No logs tampered with. That would raise suspicion. Better to leave everything looking ordinary — just another late-night work session.

The system locked at 23:44.

From the outside, nothing appeared broken.

But inside LegalEdge's data repositories, entire segments of sensitive legal intelligence had just walked out the door.

Section 4 — Detection & Alert

At **23:46 IST**, the otherwise quiet SOC floor registered a single High-severity alert in the Microsoft Sentinel Incidents queue. No alert tone sounded — not for High — but on Priya's screen, the new incident slid into the top position, pushing older Medium alerts downward.

Incident Title: *"Potential Data Exfiltration — High Volume SharePoint Download (Purview DLP)"*
Severity: High
Entities:

- User: *rahul.verma@legaledge.in*
- Workload: SharePoint Online
- Device: Unmanaged (Browser Session)
  Timestamp: 23:45:12 IST

The alert originated from a Microsoft Sentinel analytics rule ingesting signals from the **OfficeActivity** table, correlated with Microsoft Purview DLP policies.

Rule Logic (KQL):

```
OfficeActivity
| where TimeGenerated > ago(30m)  // Look at last 30 minutes
| where Workload == "SharePoint"  // Focus on SharePoint activity
| where Operation == "FileDownloaded"  // Only file download events
| summarize DownloadCount = count(), TotalBytes = sum(FileSize) by UserId,
bin(TimeGenerated, 5m)
```

```
| where DownloadCount > 200 or TotalBytes > 2000000000  // Threshold: >200 files OR >2GB data
| project TimeGenerated, UserId, DownloadCount, TotalBytes
```

What triggered it:

- **UserId:** rahul.verma@legaledge.in
- **DownloadCount:** 487 files
- **TotalBytes:** 2.31 GB
- **Time Window:** 23:17–23:45 IST (28 minutes)

The rule threshold had been breached significantly — both in file count and total data volume. What made the alert more concerning was the **time of activity**. LegalEdge's normal business hours ended at 20:00 IST. Post-22:00 activity was rare and typically limited to senior partners.

The incident panel preview showed a spike graph — flat baseline for hours, then a sudden vertical surge in download activity.

Priya clicked into the incident.

Section 5 — L1 Triage

Priya Nair had been on shift for just over three hours. The SOC floor had settled into its usual night rhythm — low chatter, dimmed overhead lighting, and the hum of workstation fans. Her Sentinel window was in full screen, as always. The queue was thin — two Low alerts and one lingering Medium she had already annotated.

When the High alert appeared at **23:46 IST**, she heard the subtle notification tone through her headset — not loud, but enough. Her fingers were already on the keyboard before the mouse moved.

She didn't open the incident immediately.

First, she read the **title**.
"High volume SharePoint download…"

Her eyes flicked to the **entity** — *rahul.verma@legaledge.in*.
Not a system account. A user.

She clicked.

The incident panel expanded on the right. She read the description once, then again, slower.

“2.3 GB… 28 minutes… SharePoint…”

Her right hand moved instinctively — **Tab switch → Entity Behavior**.

The graph loaded. Last 24 hours of Rahul Verma’s activity.

Flat.

Almost completely flat.

A few document views earlier in the afternoon. One login at 18:12 IST. Then nothing… until 23:17.

Then the spike.

Priya leaned back slightly.

“That’s not normal…”

She hovered over the spike. The tooltip confirmed it — hundreds of download operations clustered tightly.

She opened **Tab 3 — Defender for Office 365 portal** to check if any related alerts existed. Nothing. No malware, no suspicious attachments.

Back to Sentinel.

She clicked into the raw event list under the alert. The filenames began to appear:

- *Client_Agreement_Draft_v12.docx*
- *M&A_Confidential_Terms.xlsx*
- *Litigation_Strategy_Notes.pdf*

Her eyes narrowed.

“These aren’t random files…”

She opened another event. The **Sensitivity Label** field showed:

“Confidential — Client Privileged”

Now she paused.

Her mind ran through possibilities:

- Could this be legitimate late-night work?
- Senior lawyer pulling documents before a case?

- But… 487 files? In 28 minutes?

She glanced at the **user profile panel**. Role: *Associate — Corporate Law Division*.

Not senior.

She opened the **timeline view** again. No prior history of bulk downloads. No similar spikes in the past week.

Then she remembered something.

Earlier that evening, during handover notes in Teams, there had been a mention — HR updates synced into Purview tags.

She quickly searched the user in the HR-integrated attributes.

Status: Resignation submitted — 3 days ago

Priya exhaled slowly.

"Okay… that changes things."

She checked the clock: **23:52 IST**.

Six minutes since alert.

She flipped to her **Sentinel Incident Comments panel** and began typing — full sentences, no shorthand.

"User rahul.verma@legaledge.in triggered DLP alert due to 487 SharePoint file downloads totaling 2.31GB within 28 minutes (23:17–23:45 IST).
Entity behavior shows no prior pattern of high-volume downloads. Activity occurred outside business hours.
Files accessed include multiple 'Confidential — Client Privileged' labeled documents.
HR attribute indicates user submitted resignation 3 days prior.
Initial assessment: Potential insider data exfiltration."

She stopped typing.

Read it once.

Then moved to Teams.

SOC-Incidents channel.

Her escalation had to be precise.

She typed:

@Rohan Desai — Escalation (High → Potential Critical)

Alert: Purview DLP — High volume SharePoint download

Key Facts:

- User: rahul.verma@legaledge.in (Associate, Corporate Law)
- 487 files downloaded (2.31GB) in 28 mins (23:17–23:45 IST)
- Multiple files labeled "Confidential — Client Privileged"
- Activity outside business hours
- No prior history of bulk downloads
- HR flag: user resigned 3 days ago

Initial Assessment: Strong indicator of insider data exfiltration

Request: Need full audit of accessed documents, classification level, and any external sharing/upload activity post-download

She hit send at **23:55 IST**.

Then she hovered over the incident status.

After half a second's hesitation — just enough to confirm her own judgment — she updated the severity:

High → Critical

And assigned it to Rohan.

Section 6 — L2 Investigation

Rohan Desai wasn't physically on the SOC floor. At **23:56 IST**, his phone buzzed on the side table — a Teams notification. He picked it up, already unlocking it before reading.

Priya's escalation.

He read it once, slowly. Then again.

He didn't open Sentinel immediately.

Instead, he stayed on the message, parsing her reasoning.

"487 files… resignation… confidential labels…"

He nodded slightly.

“Good catch.”

Only then did he move to his workstation and connect remotely into the SOC environment. His three-monitor layout came alive — Sentinel on the left, KQL workspace center, Azure/Defender portals on the right.

00:00 IST. Investigation begins.

Step 1 — Understanding Scope

He opened the Sentinel incident and expanded the **investigation graph**.

Single user. Single workload. No immediate external entities.

“Clean… too clean.”

That meant one thing — he needed to reconstruct everything manually.

He opened **Notepad++** — his KQL scratchpad.

First question:

“Exactly what did this user download?”

Query 1 — Full Download Activity Breakdown

```
// Question: What files did the user download, and what is their classification?
OfficeActivity
| where TimeGenerated between (datetime(2026-04-16 23:00:00) .. datetime(2026-04-17 00:00:00))  // Investigation window
| where UserId == "rahul.verma@legaledge.in"  // Target user
| where Operation == "FileDownloaded"  // Only downloads
| project TimeGenerated, SourceFileName, FileSize, SensitivityLabel, Site_Url
| order by TimeGenerated asc
```

Result:

A scrolling list of nearly 500 entries.

He didn’t read all of them. He sampled.

- High concentration of **M&A documents**

- Several **litigation case files**
- Multiple **client contracts under active negotiation**

He added a quick aggregation.

```
// Summarize by sensitivity label
OfficeActivity
| where TimeGenerated between (datetime(2026-04-16 23:00:00) .. datetime(2026-04-17 00:00:00))
| where UserId == "rahul.verma@legaledge.in"
| where Operation == "FileDownloaded"
| summarize TotalFiles = count(), TotalSize = sum(FileSize) by SensitivityLabel
```

Result:

- Confidential — Client Privileged: **312 files**
- Internal Use Only: **175 files**

Rohan leaned back.

“This isn’t random. This is targeted collection.”

Step 2 — Was Data Exfiltrated Further?

Downloading isn’t exfiltration by itself.

Next question:

“Did the user upload or share this data externally after downloading?”

Query 2 — External Sharing / Upload Activity

```
// Question: Did the user share or upload files externally after download?
OfficeActivity
| where TimeGenerated > datetime(2026-04-16 23:00:00)
| where UserId == "rahul.verma@legaledge.in"
| where Operation in ("SharingSet", "FileUploaded", "AnonymousLinkCreated")  // External sharing indicators
| project TimeGenerated, Operation, SourceFileName, DestinationUrl, UserId
| order by TimeGenerated asc
```

Result:

Empty.

No sharing links. No uploads.

He frowned.

“Either staged… or exfil happened outside monitored channels.”

Step 3 — Device Context

He pivoted.

If not SharePoint sharing, then local exfil.

He switched to **DeviceFileEvents** and **DeviceNetworkEvents**.

But there was a problem.

The alert indicated **browser session — unmanaged device**.

“Right… personal device.”

That meant no Defender telemetry.

He noted it down.

“Data downloaded to unmanaged endpoint → blind spot.”

Step 4 — Timeline Reconstruction

He began building the timeline.

Timestamp (IST)	**Event**	**Data Source**	**MITRE Technique**
23:17	User logs into SharePoint	SigninLogs	T1078 (Valid Accounts)
23:18–23:45	Bulk file downloads begin (487 files)	OfficeActivity	T1213 (Data from Information Repositories)
23:45	Activity stops abruptly	OfficeActivity	—

No follow-up activity.

Clean exit.

Step 5 — IOC Table

IOC	Type	Source	Enrichment Result
rahul.verma@legaledge.in	User Account	OfficeActivity	Internal employee, flagged resignation
SharePoint URLs (multiple)	Resource	OfficeActivity	Internal legal repositories
Browser session (Unmanaged)	Device	SigninLogs	No Defender visibility

(No external IPs flagged — session appeared normal geographically.)

Step 6 — MITRE Mapping

- **T1213 — Data from Information Repositories** (Primary action)
- **T1078 — Valid Accounts** (Legitimate access used)

Step 7 — Conclusion

Rohan looked back at Priya's escalation.

She had called it early.

He typed into the incident:

"User conducted targeted bulk download of sensitive legal documents shortly after resignation submission. No evidence of external sharing within monitored systems. Activity performed via unmanaged device — potential data exfiltration outside visibility controls. Classified as confirmed insider threat — data staging for exfiltration."

Step 8 — Containment Recommendations

He didn't write generic steps. He wrote actions.

1. **Immediately disable user account** in Azure AD and revoke all active sessions

2. **Invalidate SharePoint access tokens** using Conditional Access session controls
3. **Audit and revoke external access links** across all accessed SharePoint sites
4. **Trigger Purview eDiscovery case** for full audit of accessed documents
5. **Notify HR and Legal** — initiate insider threat protocol
6. **Block unmanaged device access** via Conditional Access policy (require compliant device for SharePoint access)
7. **Review DLP policies** — enforce download restrictions on "Confidential — Client Privileged" labeled files

He hit save.

Then leaned back.

The incident had no malware. No attacker infrastructure. No lateral movement.

Just a user… and intent.

And sometimes, that was harder to detect.

Section 7 — L3 Detection Tuning

Nisha Kapoor read the incident report in silence.

Her desk sat behind Rohan's — slightly elevated, giving her a clear line of sight to the SOC floor. But her attention wasn't on the room. It was on the Word document open across her ultra-wide monitor — Rohan's investigation notes, Priya's escalation, the timeline, the IOC table.

She scrolled back to the beginning.

"23:17… first download."

Then to the alert trigger.

"23:45… detection fires."

She paused.

Twenty-eight minutes.

She leaned back slightly, arms crossed.

"That's the gap."

The system had worked — it detected the behavior. But not early enough. By the time the threshold was breached, **over 2GB of sensitive legal data had already left SharePoint**.

She turned to her right and opened the **Microsoft Sentinel Analytics Rules editor**. The rule name appeared immediately:

“High Volume SharePoint Download — DLP Threshold Breach”

She opened the query.

Before-State KQL Rule

```
OfficeActivity
| where TimeGenerated > ago(30m)
| where Workload == "SharePoint"
| where Operation == "FileDownloaded"
| summarize DownloadCount = count(), TotalBytes = sum(FileSize) by UserId,
bin(TimeGenerated, 5m)
| where DownloadCount > 200 or TotalBytes > 2000000000
| project TimeGenerated, UserId, DownloadCount, TotalBytes
```

She read it once.

Then again, slower.

“It’s purely threshold-based…”

No context. No user risk. No time-of-day awareness. No HR signal integration.

She opened Notepad++ and began typing.

Identified Weakness (Single Sentence):
The rule detects only high-volume downloads after they occur, without incorporating contextual risk signals such as after-hours activity or offboarding status, resulting in delayed detection.

She started writing the improved version.

After-State KQL Rule (Improved)

```
// Detect abnormal SharePoint downloads with contextual risk signals
let DownloadActivity =
   OfficeActivity
   | where TimeGenerated > ago(30m)
   | where Workload == "SharePoint"
   | where Operation == "FileDownloaded"
   | summarize DownloadCount = count(), TotalBytes = sum(FileSize) by UserId,
bin(TimeGenerated, 5m);

// Join with Azure AD user risk / HR tag (simulated via IdentityInfo or custom table)
let RiskyUsers =
   IdentityInfo
   | where AccountStatus == "Active"
   | where RiskState == "AtRisk" or JobTitle contains "Resigned";  // HR-fed attribute or risk
signal

DownloadActivity
| join kind=leftouter RiskyUsers on $left.UserId == $right.AccountUPN
| extend AfterHours = iff(datetime_part("hour", TimeGenerated) < 6 or datetime_part("hour",
TimeGenerated) > 21, 1, 0)
// Trigger earlier with lower thresholds if contextual risk is present
| where (DownloadCount > 100 or TotalBytes > 1000000000)  // Lower threshold
   or (AfterHours == 1 and DownloadCount > 50)  // After-hours sensitivity
   or (RiskState == "AtRisk" and DownloadCount > 25)  // High-risk users trigger faster
| project TimeGenerated, UserId, DownloadCount, TotalBytes, AfterHours, RiskState
```

She stopped typing and reviewed it line by line.

“This would have triggered at… what, 23:22?”

She mentally replayed the timeline.

Yes — within minutes of the activity starting.

She documented her reasoning:

“The improved rule introduces contextual awareness by incorporating after-hours behavior and user risk signals (e.g., resignation status). It reduces the detection threshold dynamically for higher-risk scenarios, enabling earlier alerting before large-scale data exfiltration completes.

This shifts detection from reactive (post-exfiltration) to proactive (early-stage abnormal behavior).”

She saved the draft.

Then opened the MITRE ATT&CK Navigator briefly — confirming mapping consistency.

Satisfied, she closed the editor.

The detection hadn’t failed.

But now, it would be faster.

And in insider threats, speed was everything.

Section 8 — Final Incident Report

Part A — Executive Summary (Non-Technical)

A departing employee accessed and downloaded a large volume of sensitive legal documents outside of normal working hours. The activity involved confidential client data and was not consistent with the employee’s normal behavior.

The incident was detected and investigated promptly. The user’s access has been revoked, and no further unauthorized sharing within company systems was identified. However, due to the use of an unmanaged device, there is a risk that data may have been taken outside the organization.

Immediate containment actions were taken, and additional controls are being implemented to prevent similar incidents in the future.

Part B — Full Technical Summary

Incident ID: INC-20260416-004
Client: LegalEdge Law Firm
Incident Type: Insider Threat — Data Exfiltration

Attack Type

Unauthorized bulk download of sensitive SharePoint data by internal user (post-resignation scenario)

MITRE ATT&CK Techniques

- **T1213** — Data from Information Repositories
- **T1078** — Valid Accounts

Timeline Summary

Timestamp (IST)	Event
23:17	User initiates SharePoint session
23:18–23:45	487 files downloaded (2.31GB total)
23:45	Activity ceases
23:46	Sentinel DLP alert triggered
23:55	L1 escalation to L2
00:00	L2 investigation initiated
00:25	Incident confirmed as insider threat

Impact Assessment

- **Data Exposure Risk:** High
- **Data Types Involved:** Legal contracts, M&A documents, litigation files
- **Sensitivity Level:** "Confidential — Client Privileged"
- **Confirmed External Exfiltration:** Not observed within monitored systems
- **Residual Risk:** High (due to unmanaged device download)

Full IOC List

IOC	Type	Source	Enrichment Result
rahul.verma@legaledge.in	User Account	OfficeActivity	Internal employee, resignation submitted

SharePoint document libraries	Resource	OfficeActivity	Contains sensitive legal data
Unmanaged browser session	Device	SigninLogs	No endpoint telemetry available

---

Containment Actions Taken

- User account disabled in Azure AD
- All active sessions revoked
- SharePoint access tokens invalidated
- HR and Legal teams notified
- Purview audit and eDiscovery initiated
- Conditional Access updated to restrict unmanaged device access (in progress)

Lessons Learned

- High-volume thresholds alone are insufficient for early detection
- Insider threat scenarios require contextual signals (HR status, time-of-day)
- Unmanaged device access introduces significant visibility gaps
- DLP policies must enforce not just monitoring, but prevention controls

---

Action Items

Action	Owner	Priority	Target Date
Enforce Conditional Access policy blocking SharePoint access from unmanaged devices	Identity & Access Team	Critical	20-Apr-2026
Integrate HR offboarding status into Sentinel detection rules	Security Engineering (Nisha Kapoor)	High	25-Apr-2026
Implement real-time DLP blocking for “Confidential — Client Privileged” downloads	Purview Admin Team	Critical	22-Apr-2026

Conduct audit of all users with recent resignation status	SOC + HR	High	19-Apr-2026
Deploy endpoint monitoring for browser-based downloads via Defender integration	Endpoint Security Team	Medium	30-Apr-2026
Conduct insider threat awareness training for legal staff	Compliance Team	Medium	05-May-2026

Incident Status: Resolved (Containment Complete, Monitoring Ongoing)